

Critical SQL Injection – Vulnerability Report

1. Title

Critical SQL Injection in 'id' Parameter Leading to Database Information Disclosure

2. Vulnerability Description

The application is vulnerable to SQL Injection in the 'id' parameter of the affected endpoint. User-supplied input is directly incorporated into backend SQL queries without proper input validation or parameterization.

This allows manipulation of the intended SQL query structure.

Successful exploitation may allow attackers to:

- Interact with the backend database
- Enumerate database tables and columns
- Access sensitive stored information

The vulnerability exists due to dynamic SQL query construction and lack of prepared statements.

3. Affected URL

[https://\[REDACTED\].php?id=5](https://[REDACTED].php?id=5)

4. Steps to Reproduce

- Navigate to the affected URL.
- Modify the 'id' parameter with malformed input.
- Submit the request.
- Observe the application response.
- The application returns a database-related error message.
- The response confirms that user input is being processed within the SQL query.

5. Impact

- Unauthorized database access
- Disclosure of sensitive information (e.g., usernames, emails, passwords)
- Enumeration of database tables and columns
- Authentication bypass possibility

- Privilege escalation risk
- Modification or deletion of critical records
- Potential full database compromise

6. Remediation

- Implement prepared statements / parameterized queries
- Apply strict server-side input validation
- Disable detailed database error messages in production
- Apply least privilege principle to database accounts
- Conduct secure code review and security testing